OT Watch — veille OT/ICS

Édition du 31 octobre 2026 · fenêtre 14 jours · générée le 2026-10-31 23:32:31 UTC

En bref : 22 CVE OT (1 CRITICAL, 1 ★ KEV) · ◆ 4 de vos actifs OT · 5 avis CISA ICS (5) · 13 entrées KEV OT

Score de risque = 0,5 x CVSS + 0,3 x EPSS + 0,2 x KEV (config.json risk_weights) — tri décroissant.

Tendances 30 jours (historique SQLite)



2026-10-02 → 2026-10-31 ■ total CVE publiées ■ nouveaux KEV

Articles éditoriaux (5)

22 octobre 2026 — CISA republication de 17 avis Siemens : vos S7-1500 en première ligne

À la une

Le 22 octobre, la CISA a republication 17 avis de sécurité Siemens (ICSA-26-295-01 à -18), dans un lot de 19 avis ICS. Derrière la masse, trois dossiers doivent retenir l'attention immédiate des exploitants de sites industriels.

Ce qui brûle maintenant

1. Le serveur web des S7-1500, noté 9.6 — sans correctif disponible. L'avis ICSA-26-295-14 regroupe les CVE-2026-63350 à CVE-2026-63357 : les fichiers trace importés (traces, CSV de signaux calculés) ne sont pas correctement nettoyés avant d'être rendus dans l'interface web. Résultat : un attaquant peut, par ingénierie sociale, faire importer un fichier piégé à un utilisateur autorisé disposant du droit « Read diagnostics » — et exécuter du JavaScript dans sa session, puis piloter le PLC dans la limite des droits de cet utilisateur. Aucune version corrigée n'est disponible à ce stade.

Action immédiate : désactiver le serveur web des S7-1500 lorsqu'il n'est pas indispensable, et restreindre les ports 80/443 aux seuls postes d'ingénierie. C'est la parade la plus efficace tant qu'aucun patch n'existe.

2. Les S7-1500 « MFP », notées 10.0. Les CPU 1518(F)-4 PN/DP MFP et les modules TM MFP embarquent un sous-système GNU/Linux additionnel touché par des centaines de CVE de composants tiers. Siemens prépare des correctifs et publie des mesures d'atténuation : appliquez-les dès leur disponibilité et isolez ces équipements.

3. Siemens Software Center déjà exploité (KEV). La CVE-2026-110936 (CWE-427, élément de chemin de recherche incontrôlé) affecte les versions < 4.0.9.8 et figure au catalogue KEV : une exploitation active est documentée. Corrigez en priorité.

Le reste du lot

Le lot couvre aussi un contournement de Secure Boot des SIMATIC IPC via une clé de test (CVE-2026-72895), RUGGEDCOM CROSSBOW, WinCC, Industrial Edge, PSS SINCAL, SENTRON 3NA COM et la bibliothèque cliente .NET de l'API S7 Webserver. La méthode reste la même : inventaire des actifs → confrontation aux 17 avis → correctifs planifiés, la plupart des sites Siemens hébergeant au moins un nœud S7-1500 ou WinCC concerné.

Sources : CISA ICSA-26-295-14 (https://www.cisa.gov/news-events/ics-advisories/icsa-26-295-14), ICSA-26-295-03 (https://www.cisa.gov/news-events/ics-advisories/icsa-26-295-03), analyse Red Tiger Security (https://www.redtigersecurity.com/advisory/siemens-cisa-ics-advisories-oct-2026), NVD (https://nvd.nist.gov/).

Menace active confirmée : des scripts générés par IA ciblent les PLC Siemens S7 (AA26-231A)

Menace active

Le 19 août 2026, la NSA, la CISA, le FBI, le DOE et l'EPA ont publié l'alerte conjointe AA26-231A : des acteurs malveillants utilisent des scripts Python générés par IA, appuyés sur la bibliothèque open source python-snap7, pour attaquer des PLC Siemens S7 exposés sur Internet via le protocole S7comm (TCP/102).

Pourquoi c'est un tournant

Jusqu'ici, écrire un exploit ICS demandait une expertise rare. L'IA abaisse radicalement cette barrière : n'importe quel acteur peut générer un script fonctionnel déguisé en outil de supervision, avec lecture/écriture de la mémoire du PLC, des données

de configuration et de la logique ladder.

Aucun CVE n'est associé à cette campagne — la vulnérabilité, c'est l'exposition elle-même : PLC accessibles depuis Internet, authentification faible, firmware obsolète. Les familles visées couvrent toute la gamme S7 : S7-200, S7-300, S7-400, S7-1200 et S7-1500, y compris les contrôleurs de sécurité F-series.

Un impact réel, pas théorique
Fin juillet 2026, une station de traitement d'eau du Minnesota a été perturbée ; environ 30 systèmes d'eau ont été affectés dans au moins sept États. Les agences qualifient la menace d'« active » : ce ne sont plus de la reconnaissance théorique mais du pré-positionnement opérationnel.

Checklist pour les exploitants
- Retirer les PLC S7 de toute exposition Internet directe — bloquer le TCP/102 au périmètre.
- Activer les niveaux de protection Siemens et des mots de passe forts sur chaque CPU.
- Restreindre l'accès aux seuls postes d'ingénierie autorisés (listes blanches réseau).
- Surveiller le trafic S7comm (détection d'IDS dédiée, baselining des requêtes read/write).
- Vérifier l'intégrité des projets TIA Portal contre des sauvegardes hors ligne connues bonnes.

Sources : AA26-231A via ThreatAft (https://threataft.com/articles/siemens-s7-plcs-ai-generated-exploits-cisa-aa26-231a), checklist Safeguard (https://safeguard.sh/resources/blog/siemens-s7-plc-alert-aa26-231a-checklist), CISA KEV / avis (https://www.cisa.gov/). Note connexe : la librairie snap7 elle-même a une CVE-2026-111280 (écriture hors limites dans opReadArea()) — mettez à jour vos outils qui l'embarquent.

AA26-097A — acteurs iraniens : l'exfiltration de fichiers projet PLC devient le nouveau butin

Menace active

L'alerte AA26-097A de la CISA (mise à jour juillet–août 2026) documente une escalade attributed à des acteurs affiliés à l'Iran contre des PLC exposés aux États-Unis : initialement Rockwell Automation MicroLogix 1100/1400, le ciblage s'est élargi aux Schneider Electric BMX P34 / Modicon M340 et aux Siemens S7-1200, dans les secteurs eau, énergie et collectivités.

La nouveauté inquiétante
Les attaquants ne se contentent plus de perturber : ils exfiltrent les fichiers projet des PLC (logique ladder, configurations) en utilisant les logiciels d'ingénierie des éditeurs — Studio 5000 Logix Designer, EcoStruxure Control Expert, TIA Portal — exécutés sur des infrastructures louées tierces. Disposer du code de l'automate, c'est disposer de la carte exacte du process : cela prépare une manipulation de précision (modifier la logique, désactiver des alarmes) bien plus dangereuse qu'un arrêt brutal. De nouveaux IOC (IP) couvrent la période septembre 2025 – juillet 2026.

Le détail qui fait froid dans le dos
L'avis reste associé à la CVE-2021-22681, une faille d'authentification sur des PLC exposés, sans correctif possible (« unpatchable »). Autrement dit : pour cette classe de risque, le seul remède est architectural.

Ce que cela change pour la défense OT
- L'intégrité du code automate devient un enjeu de sécurité à part entière : hash des projets, sauvegardes hors ligne immuables, comparaison régulière, détection des modifications dans les blocs de code réutilisables (AOI).
- Segmentez et filtrez les protocoles industriels : un PLC n'a jamais besoin d'être joignable depuis Internet ni depuis le réseau bureautique.
- Verrouillez les postes d'ingénierie (les « crown jewels » de l'OT) : MFA, droits minimaux, journalisation des téléchargements de projet vers les CPU.

Sources : Tenable — coordinated cyberattack on Minnesota water utilities (https://www.tenable.com/blog/coordinated-cyberattack-on-minnesota-water-utilities-what-you-need-to-know), Breached.company — CISA AA26-097A (https://breached.company/cisa-national-water-sector-warning-plc-exposure-2026/), OT Security Wire — secteur énergie (https://otsecuritywire.com/sectors/energy/).

Le trimestre des CVE PLC : brute force à 9.3, RCE sans authentification et pièges d'ingénierie

Vulnerability watch

Au-delà des avis Siemens d'octobre, plusieurs CVE publiées en 2026 illustrent les trois grandes familles de risques pesant sur les automates.

Authentification : CVE-2026-6284 (Horner Automation, CVSS 9.3)
Les PLC Horner (programmation Cscape) n'imposent ni complexité de mot de passe, ni verrouillage après échecs (CWE-521) : un attaquant ayant un accès réseau peut bruter-forcer le mot de passe à vitesse réseau et prendre le contrôle du process. Parade : segmentation, ACL limitées aux postes d'ingénierie, mots de passe au maximum autorisé, et idéalement un point d'accès unique (jump server) avec MFA.

Exécution de code sans authentification
- CVE-2026-5817 — ABB AC500 : RCE via le serveur Modbus TCP, exploitable sans aucun identifiant sur l'une des familles de PLC les plus déployées en Europe (manufacturing, eau, agroalimentaire).
- CVE-2026-27565 / 27546 (Pepperl+Fuchs, CVSS 9.8) : upload d'un fichier IODD malveillant → script shell exécuté en root, persistant après redémarrage ; plus un contournement d'authentification. Correctif : version 1.7.4.
- CVE-2026-18963 — Siemens Industrial Edge Management (CVSS 9.1) : contournement du flux de réinitialisation Keycloak (aucune vérification e-mail) → prise de compte complète des éditions Cloud/Pro/Virtual.
- CVE-2026-12663 — Rockwell ControlFLASH ≤ V15.07 : le dossier d'installation est en écriture pour le groupe « Everyone » → exécution de code au niveau de l'utilisateur connecté.

Chaînes d'attaque IT→OT
Deux rappels sur la chaîne IT→OT : CVE-2026-59310 (VMware vCenter) — aiguë lorsque vCenter héberge historiens, HMI et SCADA virtualisés — et les escalades de privilèges locales (LPE) du noyau Linux (ex. « GhostLock », LPE root en ~5 s à haute fiabilité, signalée par OT Security Wire), qui frappent directement les historiens et passerelles OPC UA sous Linux.

Règle d'or : un PLC ou un poste d'ingénierie ne doit jamais être joignable depuis Internet. En avril 2026, Forescout recensait encore 91 000 serveurs RDP et 29 000 VNC exposés, dont 670 VNC sans authentification donnant directement sur des panneaux ICS/OT.

Sources : SentinelOne CVE-2026-6284 (https://www.sentinelone.com/vulnerability-database/cve-2026-6284/), SecurityOnline — firmware industriel (https://securityonline.info/industrial-firmware-vulnerabilities/), Viakoo — avis CISA sept. 2026 (https://www.viakoo.com/blog/daily-ot-security-news-september-23-2026/), CISA ICSA-26-246-03 (https://www.cisa.gov/news-events/ics-advisories/icsa-26-246-03), OT Security Wire (https://otsecuritywire.com/), Forescout via itsecalikhan (https://itsecalikhan.substack.com/p/april-2026-otics-cybersecurity-the).

Veille technologies OT 2026 — IEC 62443, NIS2, OPC UA, Modbus : durcir sans casser la production

Technologies & standards

Standards : la conformité devient le socle
- IEC 62443 s'élargit en 2026 : la partie -1-6 couvre enfin la sécurité des dispositifs IIoT (capteurs, actionneurs connectés au cloud/edge), la -6-2 définit l'évaluation de conformité des fournisseurs, la -1-5 des profils de sécurité par application. Le référentiel passe de 4 à 6 catégories.
- NIS2 (UE) : notification d'alerte précoce sous 24 h, notification d'incident sous 72 h, rapport final sous un mois — et responsabilité personnelle des dirigeants (art. 20). Pour les entités « importantes », les sanctions atteignent 7 M€ ou 1,4 % du chiffre d'affaires mondial.
- Le modèle Purdue (zones et conduits) reste la colonne vertébrale : séparer IT, DMZ industrielle (IDMZ) et OT, avec des conduits contrôlés entre les couches.

Protocoles : le talon d'Achille historique
Modbus, DNP3, BACnet, S7comm et OPC Classic n'ont ni authentification ni chiffrement natifs : s'ils sont atteignables, des commandes d'écriture passent. Le durcissement passe par la segmentation, des IDS spécialisés ICS, des listes blanches de fonctions Modbus, et le remplacement progressif par des versions sécurisées (OPC UA avec mTLS, MQTT sur TLS).

OPC UA : puissant mais exigeant
Les failles récentes d'Eclipse Milo (bypass d'autorisation, fuite de diagnostics, oracle de padding Basic128Rsa15, DoS par quotas d'éléments surveillés) rappellent la règle : imposer mTLS, autorisation, quotas et restrictions SSRF sur chaque serveur OPC UA, notamment les passerelles IIoT (Eclipse Arrowhead/Ditto également visées).

Tendances de fond (rapports 2026)
- Le rapport Waterfall / ICS STRIVE 2026 note une baisse de 25 % des incidents à impact physique en 2025 (57 contre 76), attribuée au plateau du ransomware — mais anticipe une reprise en 2026-2027, notamment avec l arrival d'attaques « auto-entraînées » par IA côté offensif.
- Côté manufacturing, le ransomware a progressé de 56 % en 2025 (1 466 incidents documentés), avec 25 % provoquant l'arrêt complet du site.

Priorités 2026 pour une usine : (1) inventaire complet des actifs OT, (2) segmentation zones/conduits, (3) IAM strict + MFA sur les accès distants, (4) supervision passive (les vieux systèmes ne supportent pas d'agents), (5) playbooks de réponse à incident spécifiques OT, (6) sauvegardes hors ligne et testées des logiques PLC.

Sources : IIoT World — tendances ICS/OT 2026 (https://www.iiot-world.com/ics-security/ics-ot-cybersecurity-trends-2026/), IIoT World — guide manufacturing 2026 (https://www.iiot-world.com/ics-security/ot-cybersecurity-manufacturing-2026/), Deltaroot — IEC 62443 en 2026 (https://deltaroot.net/blog/iec62443-2026-ot-security-trends), Waterfall 2026 OT Cyber Threat Report (https://go.waterfall-security.com/hubfs/Gated%20content/2026%20OT%20Cyber%20Threat%20Report%20-%20Waterfall%20Security%20Solutions-1.pdf), OT Security Wire — Modbus (https://otsecuritywire.com/articles/), Agentic AI — brief OT/ICS (https://agentic-ai-daily-reports.netlify.app/cyber).

Vulnérabilités CVE surveillées (22, triées par risque)

CVE	CVSS	Sévérité	EPSS	Risque	KEV	OT
CVE-2026-110936	8.4	HIGH	1.0%	6.23	★	◆
A vulnerability has been identified in Siemens Software Center (All versions < V4.0.9.8). The affected application loads dynamic-link libraries (DLLs) [SSVC ACT]						
CVE-2026-116014	9.2	CRITICAL	0.4%	4.61		◆
open62541 1.5.0 before 1.5.7 contains an integer overflow in UA_DataType_fromStructureDescription() that wraps the 16-bit memSize field for large cust [SSVC ACT · ATT&CK ICS T0885]						
CVE-2026-92817	8.7	HIGH	0.5%	4.36		◆
The Ignition Perspective module does not properly validate session privileges when determining Designer-level access. An authenticated user with acces [SSVC TRACK*]						
CVE-2026-72895	8.4	HIGH	0.1%	4.20		◆
A vulnerability has been identified in SIMATIC IPC BX-21A (All versions < V31.01.13), SIMATIC IPC RW-543A (All versions < V1.1.4), SIMATIC IPC227G / I [SSVC TRACK*]						
CVE-2026-111280	8.3	HIGH	0.5%	4.17		
snap7 through 1.4.3 contains an out-of-bounds write vulnerability in TSnap7MicroClient::opReadArea() that allows malicious S7 peers to overflow client [SSVC TRACK]						
CVE-2026-115723	8.3	HIGH	0.4%	4.16		
Snap7 through 1.4.3 contains an out-of-bounds write vulnerability in the passive partner that allows a malicious active partner to overflow applicatio [SSVC TRACK]						
CVE-2026-109618	0.0	NONE	100.0%	3.00		
PHP uses longjmp() for out-of-memory (OOM) errors to exit the current context and abort handling of the request. Some contexts may not properly accoun [SSVC ATTEND]						
CVE-2026-109619	0.0	NONE	100.0%	3.00		
PHP has various global state that temporarily points into request memory. In some scenarios, global state may not be correctly reset, or may be repopu [SSVC ATTEND]						
CVE-2026-20182	0.0	NONE	91.8%	2.75		
May 2026: This security advisory provides the details and fix information for a vulnerability that was discovered and fixed after the was disclosed in [SSVC ATTEND]						
CVE-2026-88020	5.3	MEDIUM	0.3%	2.66		
Autonomy Logic OpenPLC 3 is susceptible to an improper neutralization of input during web page generation vulnerability when the web interface attempt [SSVC TRACK]						
CVE-2026-111497	0.0	NONE	82.6%	2.48		
A buffer overflow vulnerability in the Brotli decoder (c/dec/decode.c) in Google Brotli versions 1.0.3 through 1.2.0 on all platforms allows a remote [SSVC ATTEND]						

CVE	CVSS	Sévérité	EPSS	Risque	KEV	OT
CVE-2026-115803	2.1	LOW	0.2%	1.06		

A flaw has been found in Scada-LTS 2.8.0. Affected by this vulnerability is the function HttpServletRequest.getParameter of the file AmChartValuesAPI. [SSVC TRACK · ATT&CK ICS T0832]

CVE	CVSS	Sévérité	EPSS	Risque	KEV	OT
CVE-2026-18963	0.0	NONE	4.7%	0.14		

A flaw was found in the reset-credentials flow of the keycloak-services component, which is the core engine for identity and access management in Red [SSVC TRACK]

CVE	CVSS	Sévérité	EPSS	Risque	KEV	OT
CVE-2026-59310	0.0	NONE	2.6%	0.08		

VMware vCenter contains a directory traversal vulnerability in the Syslog server. A malicious actor with network access to vCenter may exploit this is [SSVC TRACK]

CVE	CVSS	Sévérité	EPSS	Risque	KEV	OT
CVE-2026-27565	0.0	NONE	1.0%	0.03		

An unauthenticated remote attacker can upload a malicious IODD file that places and executes a shell script with root privileges. The shell script rem [SSVC TRACK]

CVE	CVSS	Sévérité	EPSS	Risque	KEV	OT
CVE-2026-27546	0.0	NONE	1.0%	0.03		

An unauthenticated remote attacker can exploit an authentication bypass in the _account_log function to log in as an admin, even when accounts are pro [SSVC TRACK]

CVE	CVSS	Sévérité	EPSS	Risque	KEV	OT
CVE-2026-24790	0.0	NONE	0.5%	0.02		

The underlying PLC of the device can be remotely influenced, without proper safeguards or authentication. [SSVC TRACK]

CVE	CVSS	Sévérité	EPSS	Risque	KEV	OT
CVE-2026-63350	0.0	NONE	0.3%	0.01		

Affected devices do not properly restrict executable content contained in imported trace files. This could allow an attacker to social engineer an aut [SSVC TRACK]

CVE	CVSS	Sévérité	EPSS	Risque	KEV	OT
CVE-2026-63353	0.0	NONE	0.3%	0.01		

Affected devices do not properly sanitize comment fields contained in imported trace files before rendering them on the Trace page. This could allow a [SSVC TRACK]

CVE	CVSS	Sévérité	EPSS	Risque	KEV	OT
CVE-2026-63354	0.0	NONE	0.3%	0.01		

Affected devices do not properly validate and sanitize visual marker data contained in imported CSV trace files before rendering it on the Trace page. [SSVC TRACK]

CVE	CVSS	Sévérité	EPSS	Risque	KEV	OT
CVE-2026-6284	0.0	NONE	0.4%	0.01		

An attacker with network access to the PLC is able to brute force discover passwords to gain unauthorized access to systems and services. The limited [SSVC TRACK · ATT&CK ICS T0846]

CVE	CVSS	Sévérité	EPSS	Risque	KEV	OT
CVE-2026-12663	0.0	NONE	0.2%	0.00		

A security issue exists within ControlFLASH™, where the installer grants write permissions to the "Everyone" group on a product installation directory [SSVC TRACK]

Avis CISA ICS (5)

ICSA-26-302-03 — Hitachi Energy CoreTec Product (Wed, 28 Oc)

Hitachi Energy CoreTec Product mstradling Oct 28, 2026 Release Date October 29, 2026 Description View CSAF Summary Hitachi Energy is aware of OS command injection and Dirty Frag vulnerabilities that affect CoreTec produc

ICSA-26-302-02 — Hitachi Energy TRO600 series products (Wed, 28 Oc)

Hitachi Energy TRO600 series products mstradling Oct 28, 2026 Release Date October 29, 2026 Description View CSAF Summary Hitachi Energy is aware of multiple vulnerabilities that affect the TRO600 series product versions

ICSA-26-302-01 — Siemens Mendix SAML Module (Wed, 28 Oc)

Siemens Mendix SAML Module mstradling Oct 28, 2026 Release Date October 29, 2026 Description View CSAF Summary Mendix SAML module contains an authentication bypass vulnerability that could allow an unauthenticated remote

ICSA-26-300-02 — Mitsubishi Electric and Mitsubishi Electric Iconics Digital Solutions GENESIS, GENESIS64, ICONICS Suite, Hyper Historian, AnalytiX, MobileHMI, IoTWorX, MC Works64, GENESIS32 and BizViz (Mon, 26 Oc)

Mitsubishi Electric and Mitsubishi Electric Iconics Digital Solutions GENESIS, GENESIS64, ICONICS Suite, Hyper Historian, AnalytiX, MobileHMI, IoTWorX, MC Works64, GENESIS32 and BizViz mstradling Oct 26, 2026 Release Dat

ICSA-26-300-01 — EPICS Base (Mon, 26 Oc)

EPICS Base mstradling Oct 26, 2026 Release Date October 27, 2026 Description View CSAF Summary Successful exploitation of these vulnerabilities could allow an attacker to cause a denial-of-service condition, corrupt memo

KEV — exploitées dans la nature, filtre OT (13)

CVE-2026-110936	Siemens Software Center — ajouté le 2026-10-20
CVE-2021-22681	Rockwell Multiple Products — ajouté le 2026-03-05
CVE-2021-26828	OpenPLC ScadaBR — ajouté le 2025-12-03
CVE-2021-26829	OpenPLC ScadaBR — ajouté le 2025-11-28
CVE-2025-27915	Synacor Zimbra Collaboration Suite (ZCS) — ajouté le 2025-10-07
CVE-2024-21893	Ivanti Connect Secure, Policy Secure, and Neurons — ajouté le 2024-01-31 ☠
CVE-2023-46805	Ivanti Connect Secure and Policy Secure — ajouté le 2024-01-10 ☠
CVE-2024-21887	Ivanti Connect Secure and Policy Secure — ajouté le 2024-01-10 ☠
CVE-2023-6448	Unitronics Vision PLC and HMI — ajouté le 2023-12-11
CVE-2021-3129	Laravel Ignition — ajouté le 2023-09-18 ☠
CVE-2018-7841	Schneider Electric U.motion Builder — ajouté le 2022-04-15
CVE-2017-12235	Cisco IOS software — ajouté le 2022-03-03
CVE-2016-8562	Siemens SIMATIC CP — ajouté le 2022-03-03